

EVALUACIÓN DEL MÓDULO 6

Yosselinne Navarro

Lección 1: Seguridad de la Información y Fundamentos

- **Diagnóstico del estado actual:**
 - Falta de segmentación de red y ausencia de principios de mínimo privilegio.
 - Inexistencia de un inventario formal de activos y de políticas de cifrado consistentes.
 - Fugas y pérdidas de datos por error humano y desorden operativo.
- **Inventario y valoración de activos críticos:**

Activo	Tipo	Criticidad	Justificación de Negocio
Base de Datos de Clientes y Cobros	Datos	Alta	Contiene PII y datos financieros; una filtración genera sanciones legales y pérdida reputacional.
Código Fuente y Repositorios	Software/IP	Alta	Núcleo de los servicios digitales y ventaja competitiva de la empresa.
Servidores Web y API Gateways	Infraestructura	Alta	Punto de contacto con los clientes; su caída detiene la facturación en tiempo real.
Puestos de Trabajo (Laptops)	Hardware	Media	Vector de entrada potencial para malware o fuga incidental de credenciales.

- **Relación con la Tríada CID:**
 - **Confidencialidad:** Cifrado en reposo y tránsito para evitar que personal no autorizado o atacantes lean los datos de clientes.
 - **Integridad:** Empleo de funciones hash y firmas digitales para garantizar que el código y las transacciones no sean alterados.
 - **Disponibilidad:** Arquitecturas redundantes y respaldos para garantizar que la plataforma opere sin interrupciones.
- **Esquema SGSI según Ciclo PDCA (ISO/IEC 27001):**
 - **Plan (Planificar):** Delimitar el alcance del SGSI, inventariar activos, realizar la evaluación de riesgos (metodología MAGERIT o ISO 27005) y redactar la Política General de Seguridad.

- **Do (Hacer):** Implementar controles de acceso (RBAC), cifrado de discos (BitLocker/LUKS) y talleres de concienciación.
- **Check (Verificar):** Auditorías internas, revisión de registros SIEM y análisis de vulnerabilidades periódicos.
- **Act (Actuar):** Aplicar acciones correctivas ante brechas detectadas y optimizar los controles de seguridad.

Lección 2: Introducción a la Ciberseguridad y Vectores de Ataque

- **Matriz de amenazas y medidas de mitigación:**

Vector / Ataque	Origen	Impacto	Mecanismos de Mitigación Técnicos
Phishing / Spear Phishing	Externo	Robo de credenciales y acceso inicial	Pasarela de correo segura (SPF, DKIM, DMARC), autenticación multifactor (MFA) obligatoria y simulaciones periódicas.
Ransomware	Mixto	Cifrado malicioso y secuestro de datos	EDR en endpoints, aislamiento de red (Zero Trust), respaldos inmutables fuera de línea (regla 3-2-1).
DDoS (Denegación de Servicio)	Externo	Indisponibilidad de servicios web	Mitigación perimetral con WAF/CDN (Cloudflare/AWS Shield), rate-limiting y balanceadores elásticos.
Fuga Interna (Insider Threat)	Interno	Pérdida de propiedad intelectual o error	DLP (Data Loss Prevention), monitoreo de actividades anómalas y principio de mínimo privilegio.

- **Programa de concienciación para empleados:**
 - Campañas mensuales de simulación de correos maliciosos con retroalimentación inmediata.
 - Política de contraseñas seguras y uso prohibido de dispositivos USB personales (bloqueo por GPO).
 - Protocolo claro de notificación ante incidentes (*report phishing button*).

Lección 3: Protección de Datos y Controles de Acceso

- **Clasificación de la información:**
 - **Pública:** Catálogo web, datos institucionales accesibles a cualquier usuario.
 - **Interna:** Procedimientos operativos, manuales y minutas de reuniones no críticas.
 - **Confidencial:** Código fuente, configuraciones de infraestructura y contratos de clientes.
 - **Restringida:** Credenciales maestras, llaves criptográficas y datos de tarjetas de pago.
- **Estrategia Criptográfica:**
 - **Cifrado Simétrico (AES-256):** Para el cifrado masivo de bases de datos y discos en reposo (bajo consumo de CPU y alta velocidad).
 - **Cifrado Asimétrico (RSA 4096 / ECC secp256r1):** Para intercambio seguro de llaves de sesión (TLS 1.3) y firmas digitales.
 - **Enmascaramiento y Tokenización:** Mostrar números de tarjeta ofuscados (****-****-****-1234) en paneles de administración.
- **Modelo AAA (Authentication, Authorization, Accounting):**
 - **Autenticación:** Identidad validada mediante SSO (SAML/OAuth2) + MFA basado en tokens TOTP o llaves FIDO2.
 - **Autorización:** Control de acceso basado en roles (RBAC) restrictivo.
 - **Auditoría:** Registros inmutables centralizados en un SIEM registrando quién, cuándo y a qué recurso accedió.

Lección 4: Integridad de los Datos y Mecanismos de Firma

- **Riesgos a la integridad:** Modificación arbitraria de registros contables, inyecciones de código malicioso en repositorios (supply chain attacks) y corrupción de bases de datos por caídas de energía.
- **Controles según temporalidad:**
 - **Preventivos:** Validación de entradas en APIs para evitar inyecciones SQL/XSS y controles de concurrencia en bases de datos.
 - **Detectivos:** Cálculo y verificación automática de hashes (SHA-256) en transferencias de archivos y monitoreo de integridad de archivos (FIM con Wazuh/OSSEC).
 - **Correctivos:** Restauración automática de bloques corruptos desde réplicas sincrónicas y registros *Write-Ahead Logging* (WAL).

- **Infraestructura de Certificados y Firmas Digitales:**
 - Implementación de una Entidad Certificadora (CA) interna para firmar commits en Git y validar microservicios mediante mTLS (Mutual TLS).

Lección 5: Disponibilidad, Continuidad y Resiliencia

- **Métricas de Disponibilidad (Regla de los "Cinco Nueves"):**
 - **Objetivo:** 99.999% de uptime anual (equivale a menos de 5.26 minutos de inactividad no planificada al año).
 - **Sistemas críticos asignados:** API Gateway de pagos y autenticación centralizada.
- **Métricas RTO y RPO:**
 - **RPO (Recovery Point Objective):** ≤ 15 minutos. Máxima pérdida de datos tolerada ante un desastre (respaldos de transacciones continuos).
 - **RTO (Recovery Time Objective):** ≤ 1 hora. Tiempo máximo permitido para recuperar la operatividad total del servicio.
- **Fases del Plan de Respuesta a Incidentes (NIST SP 800-61):**
 1. *Preparación:* Herramientas de análisis, formación del CSIRT y canales de comunicación fuera de banda.
 2. *Detección y Análisis:* Alertas tempranas en SIEM ante picos anormales de tráfico o errores 500.
 3. *Contención:* Aislamiento de subredes y máquinas comprometidas de forma dinámica.
 4. *Erradicación:* Eliminación de artefactos de malware y revocación de credenciales expuestas.
 5. *Recuperación:* Restauración desde copias limpias y monitoreo reforzado.
 6. *Lecciones Aprendidas:* Documentación post-mortem e incorporación de nuevos indicadores de compromiso (IoC).

Lección 6: Alineación con los 8 Dominios de (ISC)² y Hardening

1. Mapeo Integral de los 8 Dominios:

1. *Seguridad y Gestión del Riesgo*: Políticas alineadas a ISO 27001, planes de continuidad y cumplimiento de normativas de privacidad.
2. *Seguridad de Activos*: Clasificación de datos en 4 niveles y destrucción segura de medios.
3. *Arquitectura e Ingeniería de Seguridad*: Implementación de modelos Zero Trust y criptografía sólida.
4. *Seguridad en Redes y Telecomunicaciones*: Segmentación en VLANs, microsegmentación y túneles VPN IPsec.
5. *Gestión de Identidades y Accesos (IAM)*: Implementación de RBAC, MFA y principio de menor privilegio.
6. *Evaluación y Pruebas de Seguridad*: Escaneos regulares de vulnerabilidades y pruebas de penetración (pentesting).
7. *Operaciones de Seguridad*: Monitorización continua en SOC, gestión de parches e investigación forense.
8. *Seguridad en el Desarrollo de Software (DevSecOps)*: Análisis estático de código (SAST), análisis de dependencias (SCA) y pruebas dinámicas (DAST) en el pipeline CI/CD.

2. Directrices de Hardening (Bastionado):

- **Servidores Linux:**
 - Deshabilitar acceso SSH directo como root (PermitRootLogin no) y obligar autenticación por llaves criptográficas.
 - Cerrar puertos no utilizados y configurar firewall local con ufw o iptables.
 - Instalar utilidades de auditoría como auditd y configurar límites de intentos fallidos en fail2ban.
- **Servidores Windows:**
 - Deshabilitar protocolos obsoletos (SMBv1, TLS 1.0 y 1.1).
 - Aplicar plantillas de seguridad mediante GPO (Group Policy Objects) para restringir PowerShell en usuarios estándar.

3. Métricas de Madurez:

- **MTTD (Mean Time to Detect)**: Tiempo promedio para identificar una anomalía.
- **MTTR (Mean Time to Respond)**: Tiempo promedio en contener y neutralizar la amenaza.
- **Porcentaje de cobertura de parches críticos**: Meta de remediación dentro de las 48 horas posteriores al boletín de seguridad.